

Detectar lo que aún no conocemos: IA para la seguridad de nuestros sistemas industriales

1. Referencia del artículo académico

Autor: Inteligencia artificial aplicada a la detección de anomalías en sistemas de control industrial

Título completo: *"Intelligent Anomaly Detection System for Industrial Control Systems"*

Año de publicación: 2024

Publicado en: IEEE Xplore (conferencia/revista de ingeniería eléctrica y electrónica)

DOI / URL: <https://ieeexplore.ieee.org/document/10914427/>

2. Las tres decisiones previas al guion

Completadas antes de redactar el guion, conforme a las instrucciones de la actividad.

Decisión 1 — ¿Qué problema real tiene tu empresa que este artículo ayuda a resolver?

Nuestra empresa opera infraestructura industrial conectada a red: PLCs, sistemas SCADA y sensores de proceso que generan datos de forma continua. Los sistemas de detección actuales (**Suricata, Wazuh**) funcionan con reglas y firmas conocidas: si el ataque es nuevo, pasa completamente desapercibido. El problema no es que carezcamos de herramientas, sino que **nuestras herramientas solo detectan lo que ya conocemos**. En un entorno donde los actores de amenaza pueden permanecer meses dentro de una red OT sin activar ninguna alerta, esta limitación representa un riesgo operativo y de continuidad inaceptable.

Decisión 2 — ¿Qué concepto del artículo explico y cuál omito, y por qué?

Explico: el concepto central del artículo: un sistema de detección basado en **aprendizaje del comportamiento normal** (self-supervised learning + transformer encoder) que genera alertas ante cualquier desviación, independientemente de si el tipo de ataque es conocido o no. Es el núcleo aplicable a nuestro contexto.

Omito: la arquitectura técnica detallada del transformer encoder y la matemática del Gaussian Mixture Model (GMM). Una junta directiva no toma decisiones en base a ecuaciones: toma decisiones en base a resultados, riesgos y costes. Incluir esos detalles consumiría tiempo de exposición sin añadir valor al objetivo de la presentación, además de ser muy técnico para lo que se pide.

Decisión 3 — ¿Qué quiero que piense o haga mi audiencia al terminar?

Que aprueben el inicio de un proyecto piloto de tres meses para desplegar un sistema de detección de anomalías basado en comportamiento sobre nuestra red OT, con un presupuesto inicial acotado y un técnico dedicado al 50% durante el trimestre. La decisión que pido es concreta, de bajo riesgo y reversible: no es una transformación total de la arquitectura de seguridad, sino una prueba controlada con métricas claras de éxito.

3. Guion estructurado de la presentación

Duración objetivo: 10–11 minutos · **Formato:** presentación grabada individual · **Audiencia:** junta directiva / responsable de departamento (conocen el sector, no han leído el artículo)

DIAPOSITIVA 1 Portada

[Presentarse] [Introducir tema, a quién me dirijo] [Resumer la charla]

DIAPOSITIVA 2 El problema

Imaginad que hay alguien dentro de nuestra red industrial ahora mismo.
No está haciendo nada todavía. Solo está mirando. Aprendiendo cómo funcionamos.
Esperando.
¿Cuánto tiempo tardaríamos en darnos cuenta?
El problema es estructural: nuestros sistemas de detección actuales funcionan con firmas y reglas predefinidas.
Mencionar dato de 200+ días.
Si el ataque entra dentro de esa lista, lo detectamos. Si no está en la lista, pasa completamente desapercibido.
Y los atacantes lo saben.
Este número refleja casos reales documentados. No es un escenario teórico. Es lo que ocurre cuando las herramientas de detección no están diseñadas para el entorno OT.

DIAPOSITIVA 3 El sector ya está respondiendo

Esto no es nuevo. El sector lleva años pagando el precio de esta vulnerabilidad.

Colonial Pipeline, 2021: un grupo de ransomware entró por una contraseña VPN sin autenticación de doble factor. Sin más. La pipeline que suministra el 45% del combustible de la costa este de Estados Unidos estuvo parada cinco días. Rescate pagado: 4,4 millones de dólares.

Red eléctrica de Ucrania, 2015 y 2016: primer ciberataque documentado que causó apagones masivos reales. Más de 230.000 hogares sin electricidad. Vector de entrada: correos de phishing dirigidos a operadores de SCADA.

Stuxnet, 2010: el primer arma cibernética diseñada específicamente para PLCs Siemens. Destruyó centrifugadoras de enriquecimiento nuclear sin disparar un solo tiro. Demostró que los sistemas OT son objetivos estratégicos de primer nivel, no solo industriales.

Ante este panorama, la comunidad investigadora lleva varios años desarrollando un enfoque completamente distinto al de las firmas: detección basada en comportamiento. El artículo de IEEE que he revisado recoge precisamente los avances más recientes en esa línea.

DIAPOSITIVA 4 La innovación: detección por comportamiento normal

Pensad en un guardia de seguridad que lleva años trabajando en el mismo edificio. Conoce tan bien la rutina — quién entra, a qué hora, por dónde — que detecta cualquier cosa fuera de lo normal aunque nunca haya visto ese tipo de intrusión antes. Eso es exactamente lo que hace este sistema. No busca el ataque conocido. Detecta lo que no debería estar ocurriendo.

DIAPOSITIVA 5 El sistema en tres pasos

El funcionamiento es sencillo de explicar en tres fases.

Primera: aprendizaje. Durante las primeras semanas, el modelo observa el comportamiento normal de la red OT sin intervenir. Aprende qué es la línea base.

Segunda: vigilancia continua. A partir de ahí, monitoriza en tiempo real comparando lo que ocurre con lo que aprendió.

Tercera: alerta. Cualquier desviación significativa del patrón aprendido genera una alerta, conocida o desconocida.

Lo más relevante para nosotros: el sistema no necesita que nadie le enseñe cómo es un ataque. Aprende solo qué es lo normal. Y eso lo cambia todo.

DIAPPOSITIVA 6 Aplicado a nuestra infraestructura

Primero: los datos ya están ahí. Nuestros PLCs y sistemas SCADA generan flujos de datos de proceso de forma continua — temperatura, presión, caudal, estado de actuadores. Exactamente el tipo de señal que este modelo necesita para aprender. No hay que construir nada nuevo para alimentarlo.

Segundo: no requiere tocar la infraestructura existente. El sistema opera en modo pasivo, escuchando el tráfico sin interferir. No hay riesgo de interrupción operativa durante la prueba.

Tercero: no sustituye lo que ya tenemos. Suricata y Wazuh siguen funcionando. Este sistema añade una capa de visibilidad que ellos no pueden dar: el comportamiento interno de la red OT, no solo el tráfico de red.

DIAPPOSITIVA 7 Propuesta: piloto de 3 meses

La propuesta es concreta y de bajo riesgo.

Un piloto de tres meses, estructurado en tres fases

Mes uno: desplegamos el sistema en un entorno de prueba aislado sobre una línea de producción estable. El modelo empieza a aprender el baseline.

Mes dos: activamos la monitorización en paralelo a los sistemas actuales. Sin alertas automáticas todavía — solo recogemos datos para calibrar.

Mes tres: evaluamos las alertas generadas, medimos la tasa de falsos positivos, y decidimos si escalar.

Recursos necesarios: un técnico dedicado al cincuenta por ciento durante el trimestre, y un servidor estándar de inferencia. Modelo open-source, sin costes de licencia.

DIAPPOSITIVA 8 Lo que podría fallar y cómo lo controlamos

Antes de que lo preguntéis, he identificado los tres riesgos principales y cómo los mitigamos.

Primero: exceso de falsos positivos que sature al equipo. Mitigación: el umbral de alerta es ajustable, y en la fase dos mantenemos revisión humana antes de escalar cualquier incidencia.

Segundo: que el modelo aprenda un baseline incorrecto si la red está en estado atípico durante la fase de aprendizaje. Mitigación: el piloto arranca únicamente sobre líneas de producción en estado estable y controlado.

Tercero: coste de mantenimiento a largo plazo. Mitigación: el modelo es open-source y el equipo interno puede mantenerlo sin dependencia de proveedor externo.

DIAPOSITIVA 9 Qué conseguimos si funciona

Si el piloto confirma lo que el artículo demuestra en entornos similares, el impacto es significativo.

Obtenemos, por primera vez, visibilidad real sobre el comportamiento de nuestra red OT. Actualmente operamos sin saber con certeza qué es 'normal' en ese entorno. Este sistema nos lo dice.

Reforzamos nuestro posicionamiento ante auditorías de NIS2, obligatoria en UE, e IEC 62443, que están exigiendo activamente capacidades de detección de anomalías en infraestructuras esenciales.

Y si el piloto funciona, la solución puede extenderse a toda la infraestructura industrial sin volver a empezar desde cero o incorporarse con otras soluciones

DIAPOSITIVA 10 Cierre y llamada a la acción

La pregunta no es si nos van a atacar.

Seguro que nos atacarán, la pregunta es, cuánto tiempo tenemos para responder.

Tenemos una solución validada: publicada en IEEE, probada en entornos de control industrial reales.

Y tenemos un plan concreto, de bajo riesgo y reversible: un piloto de tres meses con recursos acotados.

Lo que pido hoy es aprobación para iniciar ese piloto en el próximo trimestre.

La única forma de saber si estamos protegidos es comprobarlo antes de que lo haga alguien por nosotros.

Nota sobre tiempos orientativos

Bloque	Tiempo	Diapositivas
Apertura	1–1,5 min	1 (portada) + 2 (el problema)
Contexto	1,5 min	3 (casos reales)
La innovación	2,5–3 min	4 (concepto) + 5 (tres pasos)
Aplicación concreta	2,5 min	6 (infra) + 7 (piloto) + 8 (riesgos)
Cierre	1,5 min	9 (resultados) + 10 (llamada a la acción)
TOTAL	~10–11 min	10 diapositivas

Recomendación: realiza al menos dos ensayos completos cronometrados antes de grabar. En el primero identifica los puntos donde aceleras o pierdes el hilo. En el segundo trabaja específicamente esas transiciones.